

DEMO

Технічний аудит WordPress-сайту

Продуктивність · Безпека · Плагіни · SEO · Доступність · План
виправлень

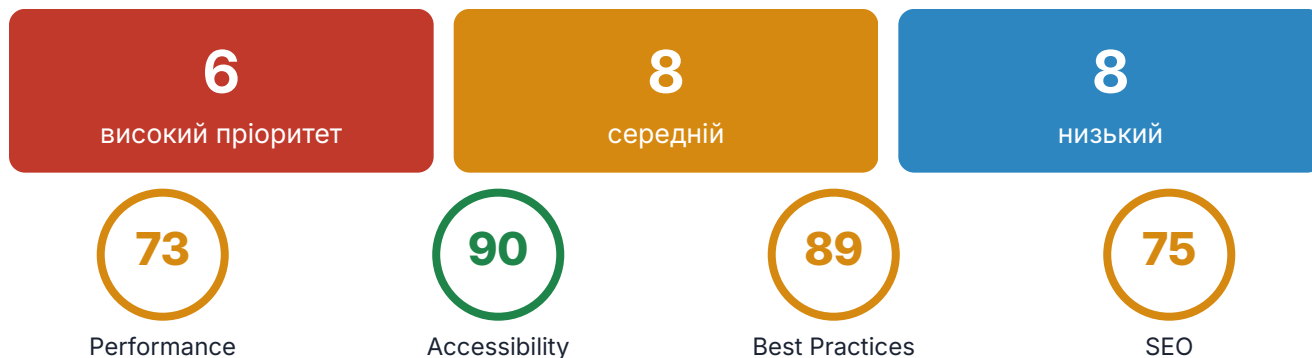
Об'єкт: лабораторний стенд «Пекарня «Колосок»» (<http://127.0.0.1:8088>)

Дата: 2026-10-09

Демо-проект для портфоліо. Сайт і бізнес вигадані; проблеми внесено навмисно.

Коротко

Перевірено головну сторінку й типові службові адреси WordPress лише GET/HEAD-запитами, плюс інвентаризацію ядра, плагінів і тем через WP-CLI та Lighthouse 12 (мобільний профіль). Знайдено **22** проблем.



Головне: PHP-помилки показуються відвідувачам, сайт працює без HTTPS і без заголовків безпеки, плагіни застарілі, а зображення по ~6.8 МБ сповільнюють сторінку. Ці пункти закриваються за 1–2 робочі дні і дають найбільший ефект.

Deprecated: Return type of WPCF7_FormTag::offsetExists(\$offset) should either be compatible with ArrayAccess::offsetExists(mixed \$offset): bool, or the #[\ReturnTypeWillChange] attribute should be used to temporarily suppress the notice in `/workspace/fh-demos/wp-audit/lab/wordpress/wp-content/plugins/contact-form-7/includes/form-tag.php` on line 395

Deprecated: Return type of WPCF7_FormTag::offsetGet(\$offset) should either be compatible with ArrayAccess::offsetGet(mixed \$offset): mixed, or the #[\ReturnTypeWillChange] attribute should be used to temporarily suppress the notice in `/workspace/fh-demos/wp-audit/lab/wordpress/wp-content/plugins/contact-form-7/includes/form-tag.php` on line 387

Deprecated: Return type of WPCF7_FormTag::offsetSet(\$offset, \$value) should either be compatible with ArrayAccess::offsetSet(mixed \$offset, mixed \$value): void, or the #[\ReturnTypeWillChange] attribute should be used to temporarily suppress the notice in `/workspace/fh-demos/wp-audit/lab/wordpress/wp-content/plugins/contact-form-7/includes/form-tag.php` on line 381

Deprecated: Return type of WPCF7_FormTag::offsetUnset(\$offset) should either be compatible with ArrayAccess::offsetUnset(mixed \$offset): void, or the #[\ReturnTypeWillChange] attribute should be used to temporarily suppress the notice in `/workspace/fh-demos/wp-audit/lab/wordpress/wp-content/plugins/contact-form-7/includes/form-tag.php` on line 399

Notice: Function `_load_textdomain_just_in_time` was called **incorrectly**. Translation loading for the `twentytwentyone` domain was triggered too early. This is usually an indicator for some code in the plugin or theme running too early. Translations should be loaded at the `init` action or later. Please see [Debugging in WordPress](#) for more information. (This message was added in version 6.7.0.) in `/workspace/fh-demos/wp-audit/lab/wordpress/wp-includes/functions.php` on line 6260

РЕЗУЛЬТАТИ АУДИТУ (ЛАБОРАТОРНИЙ СТУДІЙ)

Продуктивність

Високий Важкі неоптимізовані зображення

Що виявлено: hero0.jpg (6809 КБ), hero1.jpg (6810 КБ)

Як виправити: Стиснути та перевести у WebP/AVIF, задати розміри, srcset і loading='lazy'; ціль < 200 КБ на зображення.

Високий Lighthouse Performance 73/100 (mobile)

Що виявлено: first-contentful-paint: 2.0 s, largest-contentful-paint: 2.3 s, total-blocking-time: 10 ms, cumulative-layout-shift: 0.978, speed-index: 2.0 s

Як виправити: Оптимізація зображень, кешування сторінок, відкладене завантаження JS/CSS, CDN.

Метрика (mobile)	Значення
first-contentful-paint	2.0 s
largest-contentful-paint	2.3 s
total-blocking-time	10 ms
cumulative-layout-shift	0.978
speed-index	2.0 s

Безпека

Високий Відсутні заголовки безпеки

Що виявлено: Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options, X-Frame-Options, Referrer-Policy, Permissions-Policy

Як виправити: Додати заголовки на рівні веб-сервера (nginx/Apache) або плагіном; почати з X-Content-Type-Options, Referrer-Policy, X-Frame-Options, HSTS після переходу на HTTPS.

Високий Сайт працює без HTTPS

Що виявлено: http://127.0.0.1:8088

Як виправити: Встановити TLS-сертифікат (Let's Encrypt), 301-редірект на https, увімкнути HSTS.

Високий PHP-помилки виводяться відвідувачам

Що виявлено: На головній видно Deprecated/Notice з повними шляхами до файлів

Як виправити: WP_DEBUG_DISPLAY=false, логувати у файл поза webroot; оновити плагіни, що генерують помилки.

Середній Увімкнено XML-RPC

Що виявлено: /xmlrpc.php → 405

Як виправити: Вимкнути XML-RPC, якщо не використовуються Jetpack/мобільний застосунок (brute-force через system.multicall).

Середній Перелік користувачів через REST API

Що виявлено: /wp-json/wp/v2/users → ['admin']

Як виправити: Обмежити endpoint users для неавторизованих; не використовувати логін 'admin'.

Середній Сторінка входу без захисту від перебору

Що виявлено: /wp-login.php доступна без обмежень/2FA

Як виправити: Ліміт спроб входу, 2FA для адміністраторів, за можливості — обмеження за IP.

Середній Адміністратор з логіном «admin»

Що виявлено: user_login=admin

Як виправити: Створити нового адміністратора з унікальним логіном, перенести контент, видалити «admin».

Низький Розкривається версія PHP

Що виявлено: X-Powered-By: PHP/8.4.26

Як виправити: expose_php = Off у php.ini.

Низький Версія WordPress у кодї сторінки

Що виявлено: WordPress 7.1.3

Як виправити: Прибрати meta generator (remove_action('wp_head','wp_generator')) та ?ver= у статиці.

Низький Доступний readme.html

Що виявлено: /readme.html → 200

Як виправити: Видалити або заборонити доступ до readme.html, license.txt.

Низький Енумерація авторів через ?author=

Що виявлено: http://127.0.0.1:8088/author/admin/

Як виправити: Блокувати ?author=N редіректором/правилом сервера.

Плагіни й оновлення

Високий Застарілі плагіни: 2

Що виявлено: classic-editor 1.5 → 1.7.0, contact-form-7 5.3.1 → 6.2.1

Як виправити: Зробити резервну копію, оновити на staging, перевірити форми й редактор, потім на production. Увімкнути автооновлення безпеки.

Середній Застарілі теми

Що виявлено: twentytwentyone 1.0 → 2.9

Як виправити: Оновити активну тему (через дочірню тему, щоб не втратити правки), видалити зайві.

Низький Неактивні плагіни: 2

Що виявлено: akismet, hello

Як виправити: Видалити непотрібні плагіни — вони все одно можуть містити вразливості.

WordPress core: **7.1.3**

Плагін	Статус	Версія	Доступна
akismet	inactive	5.7.2	✓ актуальна
classic-editor	active	1.5	1.7.0
contact-form-7	active	5.3.1	6.2.1
hello	inactive	1.7.2	✓ актуальна
sqlite-database-integration	inactive	3.1.0	✓ актуальна

SEO

Середній Немає meta description

Що виявлено: головна сторінка

Як виправити: Задати унікальні description для ключових сторінок (Yoast/Rank Math або вручну).

Низький Кількість H1 на головній: 3

Що виявлено: Пекарня «Колосок» (лабораторний стенд); Ласкаво просимо; Свіжий хліб щодня

Як виправити: Один H1 на сторінку, далі логічна ієрархія H2–H3.

Низький Немає Open Graph-розмітки

Що виявлено: —

Як виправити: Додати og:title/og:description/og:image для коректних прев'ю в соцмережах.

Доступність

Середній Зображення без alt: 2

Що виявлено: tent/uploads/2026/10/hero0.jpg, tent/uploads/2026/10/hero1.jpg

Як виправити: Заповнити alt для змістовних зображень, alt="" для декоративних.

Середній Недостатній контраст тексту

Що виявлено: Lighthouse: color-contrast

Як виправити: Контраст тексту не менше 4.5:1 (WCAG AA).

Низький Неінформативні тексти посилань

Що виявлено: тут

Як виправити: Писати зміст посилання: «Замовити торт», а не «тут».

План виправлень за пріоритетом

#	Пріоритет	Проблема	Розділ	Оцінка часу
1	Високий	Відсутні заголовки безпеки	Безпека	1–2 дні
2	Високий	Сайт працює без HTTPS	Безпека	1–2 дні
3	Високий	PHP-помилки виводяться відвідувачам	Безпека	1–2 дні
4	Високий	Важкі неоптимізовані зображення	Продуктивність	1–2 дні
5	Високий	Lighthouse Performance 73/100 (mobile)	Продуктивність	1–2 дні
6	Високий	Застарілі плагіни: 2	Плагіни й оновлення	1–2 дні
7	Середній	Увімкнено XML-RPC	Безпека	2–4 год
8	Середній	Перелік користувачів через REST API	Безпека	2–4 год
9	Середній	Сторінка входу без захисту від перебору	Безпека	2–4 год
10	Середній	Немає meta description	SEO	2–4 год
11	Середній	Зображення без alt: 2	Доступність	2–4 год
12	Середній	Недостатній контраст тексту	Доступність	2–4 год
13	Середній	Застарілі теми	Плагіни й оновлення	2–4 год

14	Середній	Адміністратор з логіном «admin»	Безпека	2–4 год
15	Низький	Розкривається версія PHP	Безпека	до 1 год
16	Низький	Версія WordPress у кодї сторінки	Безпека	до 1 год
17	Низький	Доступний readme.html	Безпека	до 1 год
18	Низький	Енумерація авторів через ?author=	Безпека	до 1 год
19	Низький	Кількість H1 на головній: 3	SEO	до 1 год
20	Низький	Немає Open Graph-розмітки	SEO	до 1 год
21	Низький	Неінформативні тексти посилань	Доступність	до 1 год
22	Низький	Неактивні плагіни: 2	Плагіни й оновлення	до 1 год

Методика й обмеження

Аудит неінвазивний: без сканування вразливостей, підбору паролів і навантажувального тестування. Lighthouse виміряно на локальному стенді; на реальному хостингу значення будуть іншими. Оцінки часу орієнтовні й залежать від хостингу та теми.